

DEBSHIKHAR DAS

Security Engineer — DevSecOps · AI / Agentic Security · AppSec

917.361.6286 | debshikhar.das@outlook.com | linkedin.com/in/debshikhar | github.com/debshikhar-sec | Jersey City, NJ

Security Engineer with 3+ years scaling enterprise DevSecOps and vulnerability-management programs, specializing in embedding AI into security operations and — increasingly — securing AI itself. Built production RAG agents (LangChain, vector databases) that converted vulnerability telemetry into prioritized, context-aware remediation, and an independent agent runtime assurance and governance plane that treats every agent as a governed non-human identity — policy-as-code authorization, an enforced L0–L6 autonomy ceiling, and least-privilege A2A delegation and MCP tool access on every call. Fluent in DevSecOps automation, AppSec, STRIDE threat modeling, and the OWASP LLM / Agentic Top 10, MITRE ATLAS, and NIST AI RMF. Seeking AI-security and DevSecOps engineering roles where AI capability must be bounded by enforced, auditable authority.

PROFESSIONAL EXPERIENCE

BNP Paribas CIB — DevSecOps Engineer *(Contract via Quanteam)*

Jul 2024 – Present · Jersey City, NJ

- Designed and deployed an AI-powered RAG agent that vectorized vulnerability data from Qualys, Nexpose, Tanium, and other sources, letting remediation teams query insights in natural language — dynamically pulling from APIs or generating SQL — improving response time and decision accuracy by ~60%.
- Engineered automated pipelines integrating patch and vulnerability intelligence into the bank's internal vulnerability, obsolescence & patch-management platform, reducing manual triage by ~30%, and built an AI-driven remediation advisory engine that provides contextual recommendations.
- Integrated enriched Red Hat CVE remediation intelligence (CVSS scoring, exploit indicators) for risk-prioritized remediation, achieving ~95% SLA compliance on critical vulnerabilities.
- Operationalized a real-time obsolescence-tracking system feeding OpenSearch for predictive end-of-life detection and proactive patch planning; orchestrated a high-integrity migration from legacy JIRA tracking with data-validation pipelines and audit trails.
- Built a secure Angular/Docusaurus documentation portal for controlled management of vulnerability and patching processes, accelerating onboarding by ~40%; laid the foundation for agentic-AI adoption in vulnerability workflows.
- Turned vulnerability and code-quality telemetry into KPI dashboards and executive/regulatory reporting (advanced Excel, SQL, OpenSearch-based Application Portfolio Management on SonarQube scores); automated intake and ticketing through ServiceNow and Jira workflows.
- Enriched SIEM detections with vulnerability and obsolescence intelligence to cut false positives and speed investigations; partnered with IAM teams to embed RBAC/MFA into patching workflows, aligning controls with NIST CSF, ISO 27001, and NYSDFS.

Ernst & Young — Cybersecurity Consultant, Staff 2

Oct 2022 – Jan 2024 · New York, NY

- Developed CI/CD security infrastructure — tuned Jenkins pipelines with custom rulesets for SAST & SCA (SonarQube, Snyk), DAST, container scanning (Aqua), and fuzz testing (Burp Suite) across the SDLC.
- Spearheaded design of a scalable threat-modeling process (STRIDE), reducing intake assessment time by 25%, and scaled an automated DevSecOps toolchain that cut manual security-control validation by 50%.
- Containerized security testing (Docker → Kubernetes via YAML manifests, provisioned with Terraform), decreasing manual configuration time by 40%; authored SBoMs and SOPs and hardened cloud security documentation.
- Strengthened network segmentation with Guardicore (~30% fewer security incidents) and mitigated ransomware/DDoS risk via DMZ architecture, AWS WAF ACLs, CloudFront, Route 53, and CloudTrail monitoring.

SM Advisors — Cybersecurity Intern

Feb 2022 – May 2022 · West Hollywood, CA

- Reduced anomaly-detection time ~20% by analyzing how deployed Microsoft updates impacted live operations, and lowered intrusions ~25% by helping deploy and configure IDS/IPS, firewall rules, and log-analysis tooling.

Cisco Systems — Summer Research Intern

Jun 2018 – Aug 2018 · India

- Researched IoT / connected-vehicle threat vectors and prototyped a zero-trust architecture to mitigate remote and MITM attack paths.

Hewlett Packard Enterprise — Network Development Intern

Jul 2017 – Aug 2017 · India

- Evaluated secure network architectures and the integration of wireless technologies with cloud services.

SELECTED PROJECT

private-ai-infra — Local-First Agent Runtime Assurance & Governance Plane (independent project)

2026

github.com/debshikhar-sec/private-ai-infra · debshikhar-sec.github.io/private-ai-infra

- Designed and built a pip-installable, OpenAI-compatible local AI gateway (Python/Flask + nginx, Apple Silicon/MLX) enforcing policy-as-code identity, per-principal model authorization, and an L0–L6 autonomy ceiling on every call — denying over-privileged requests *before* any model loads.
- Extended the plane to agent-to-agent and agent-to-tool traffic: policy-derived A2A Agent Cards, skill-scoped delegation, and an MCP tool registry with per-tool minimum autonomy — least-privilege authorization for non-human identities, deny by default.
- Added egress secret-redaction guardrails, per-principal rate limiting, a decision audit, and Prometheus metrics; an assurance agent — read-only over the plane, appending signed verdicts — reconciles audit ↔ metrics ↔ policy across nine controls.
- Layered defenses around the plane: an ingress AI-firewall (prompt-injection / jailbreak / PII detection surviving Unicode homoglyph and zero-width evasion, OWASP LLM01), a versioned delegation protocol (GAD) whose conformance suite proves sub-delegated authority can only narrow, a Governed Chat Console running plan → sandboxed-apply → verify under human approval, CVE intelligence, and SIEM export.
- Wrote a 23-case adversarial eval suite (fails CI on regression) tagged to the OWASP Top 10 for LLMs / Agentic Applications and MITRE ATLAS, proving controls hold with the model assumed compromised by prompt injection.
- Separated model capability from execution authority: an owner-gated, single-use, plan-hash-bound approval loop whose authorization, execution, and outcome form a signed, tamper-evident evidence graph — HMAC-signed, hash-chained records in durable stores, wired live end-to-end and independently re-verified fail-closed; hardened with crash-safe reconciliation, signed disposition, sandbox rollback, model-build attribution, and protected-surface lanes adopted after a local model failed all 14 security-refusal tests.
- Hardened delivery: 1,300+ tests at ~92% coverage; ruff, bandit, pip-audit, CodeQL in CI; branch protection and Dependabot; documented STRIDE threat model, security model, and product roadmap.

EDUCATION

M.S. in Cybersecurity

Stevens Institute of Technology, Hoboken, NJ · Jan 2021 – Aug 2022

B.S. in Computer Science & Engineering

Amity University, Kolkata, India · Aug 2015 – Jun 2019

TECHNICAL SKILLS

AI / ML Security: OWASP LLM & Agentic Top 10, MITRE ATLAS, NIST AI RMF, prompt-injection defense, RAG security, agent identity & least-privilege authorization (A2A, MCP), autonomy/authority governance, adversarial evals

AI / ML Engineering: LangChain, LangGraph, RAG, vector databases (Qdrant, Chroma), prompt engineering, NLP, MLX

DevSecOps & CI/CD: Jenkins, GitHub Actions, SAST (SonarQube), SCA (Snyk), DAST (Qualys), container scanning (Aqua), JFrog, Nexus, SBOM, bandit, pip-audit, CodeQL

AppSec & Threat Modeling: STRIDE, OWASP Top 10, IriusRisk, ThreatModeler, OWASP ZAP, Burp Suite, secure SDLC

Cloud & Infrastructure: AWS (EC2, S3, IAM, WAF, CloudTrail, CloudFront), Docker, Kubernetes, Terraform, Ansible, OpenSearch

Languages & Frameworks: Python, Java, Shell; Flask, FastAPI; SQL (PostgreSQL, Oracle, SQLite); NIST CSF & 800-53, ISO 27001, NYSDFS

Vulnerability Management: Qualys, Nexpose, Tanium, CVE / CVSS, SLA-driven remediation, EOL tracking, ServiceNow, Jira